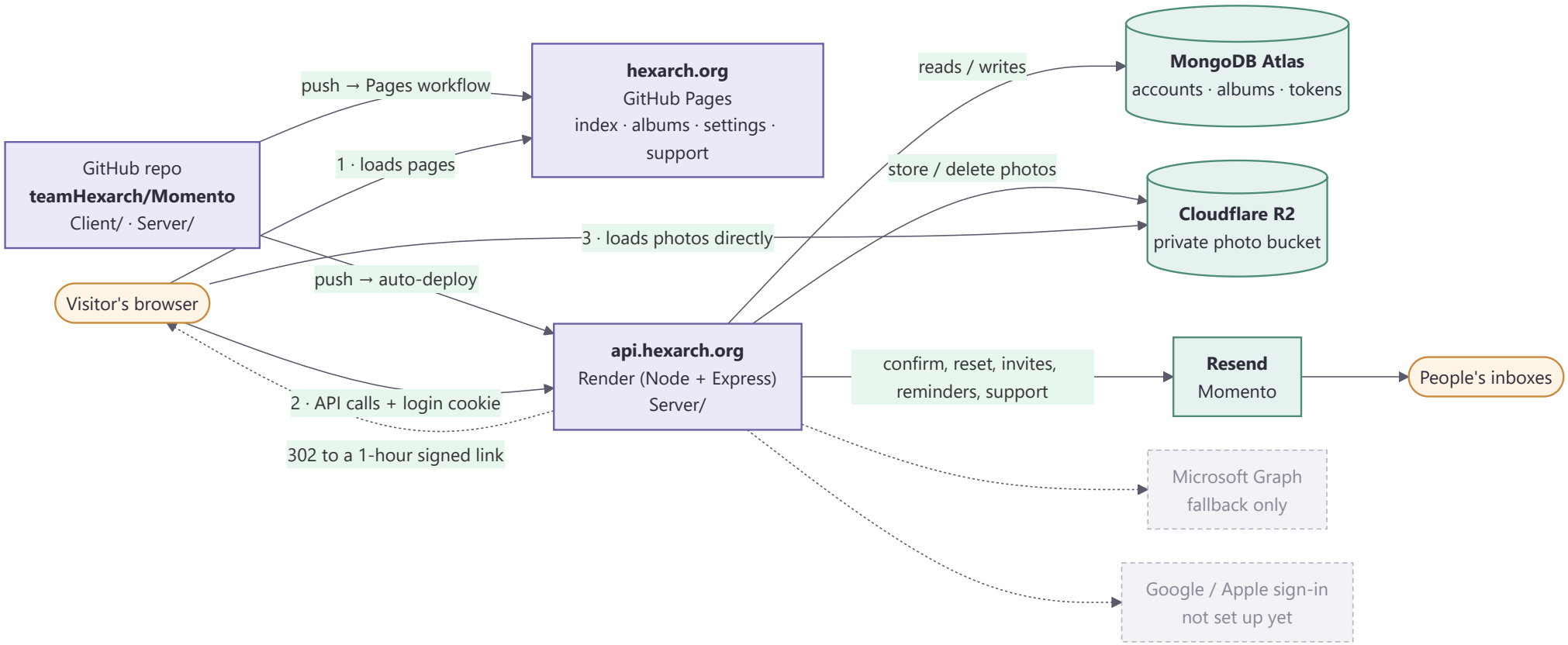
1 · The big picture

The website and the API live on two addresses of the same site, so the login cookie works in every browser. One push to GitHub updates both: Pages publishes **Client/**, Render redeploys **Server/**. Photos never stream through Render: the API checks access, then sends the browser to Cloudflare.



Ours (code in the repo) **Hosted services** (free plans) **Not in use yet** Dashed arrows: optional or one-off steps

2 · Inside the API

Server/src

Every request passes the same checks in order before it reaches a route. Routes only map URLs to **controllers**; controllers hold the rules; **services** do the work that talks to the outside world; **models** describe what's stored.

1 · Checks on every request

middleware/, in this order

cors · sameOriginWrites
Only hexarch.org may call with the cookie
Other sites' writes → 403

→

json · cookie-parser
Reads the body (max 100 kB) and the login cookie

→

loadUser
Login cookie (signed JWT) → who is it?
Issued before a password reset → logged out

→

Guards + rate limits
requireUser · requireVerified
Sign-in 20/15 min · emails 5/h
Join codes 30/h · invites 20/h · support 5/h

↓

2 · Routes → controllers

routes/ map URLs · controllers/ hold the rules

/api/auth · authController
Sign up · log in / out · me
Confirm email · reset password
Change email · delete account
Google · Apple

/api/albums · albumController
List · create · join · update · delete
Upload (10 at a time) · zip download
Remind · invite
Life cycle: upcoming → live → wrapping → kept

/api/photos/:id · photoController
View: members only, via signed R2 link
Delete: uploader or host

/api/support · supportController
Contact form → team mailbox
Reply goes straight to the sender

↓

3 · Services

services/ · the parts that talk to the outside world

accountService
Email change (confirm link + notice)
Delete account and everything it owns

verification · passwordReset
+ emailTokenService:
one-time links, only SHA-256 stored

emailService
Resend, else Microsoft Graph
+ emailTemplates

storageService
Cloudflare R2, else disk
save · send · open · delete

↓

4 · Data and outside services

models/ (Mongoose) and hosted services

MongoDB Atlas
User · Album · Membership
Photo · Invite · EmailToken

Cloudflare R2
Private bucket momento-photos
Signed 1-hour links for viewing

Resend
Momento <team@hexarch.org>
Confirm · reset · invites · reminders · support

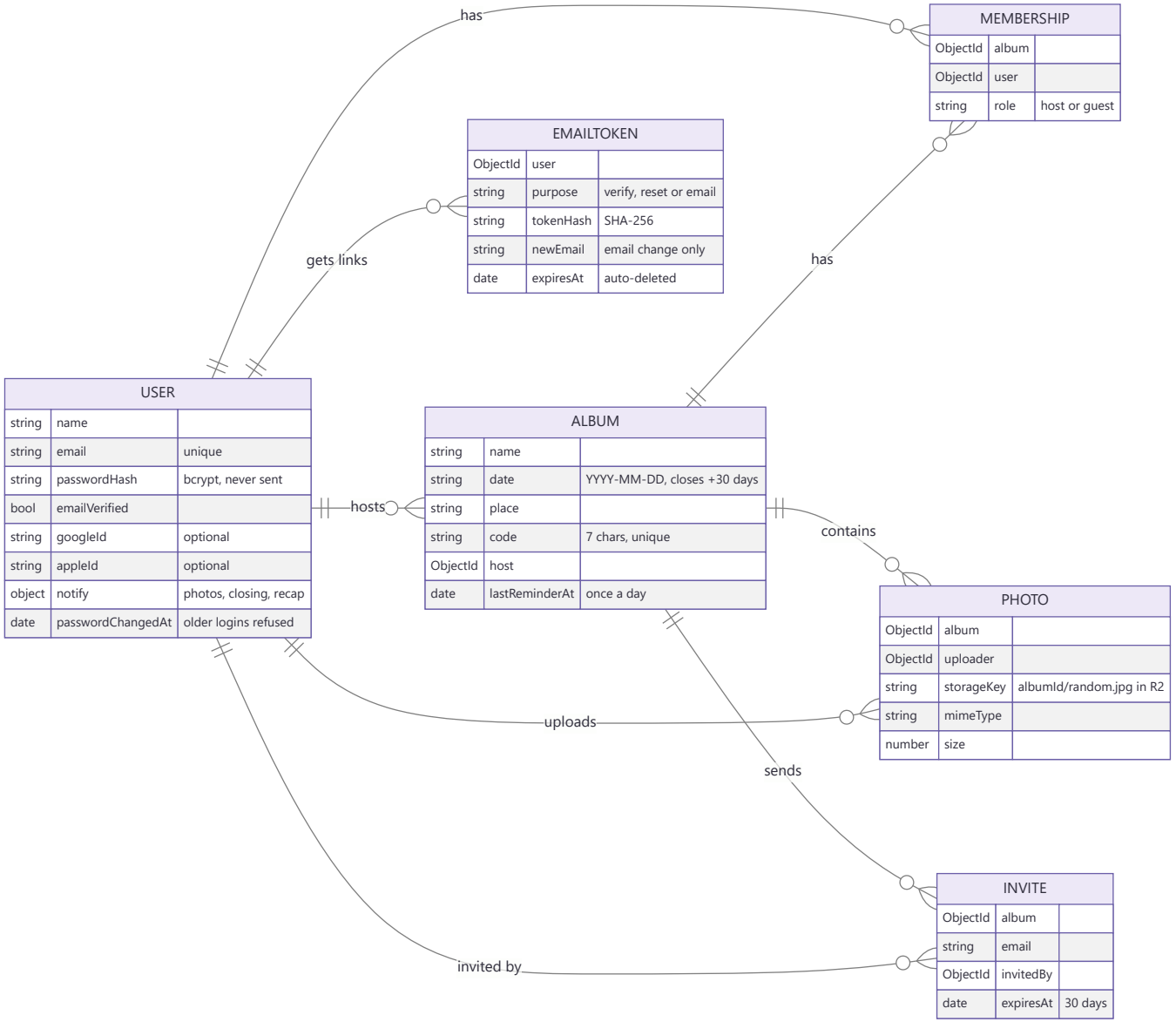
Not in use yet
Microsoft Graph (fallback)
Google / Apple sign-in keys

Errors from any step come back as { error, code? } through middleware/errorHandler.js. requireVerified (albums and photos only for confirmed emails) is on this computer and not yet deployed.

3 · The data

Server/src/models · MongoDB collections

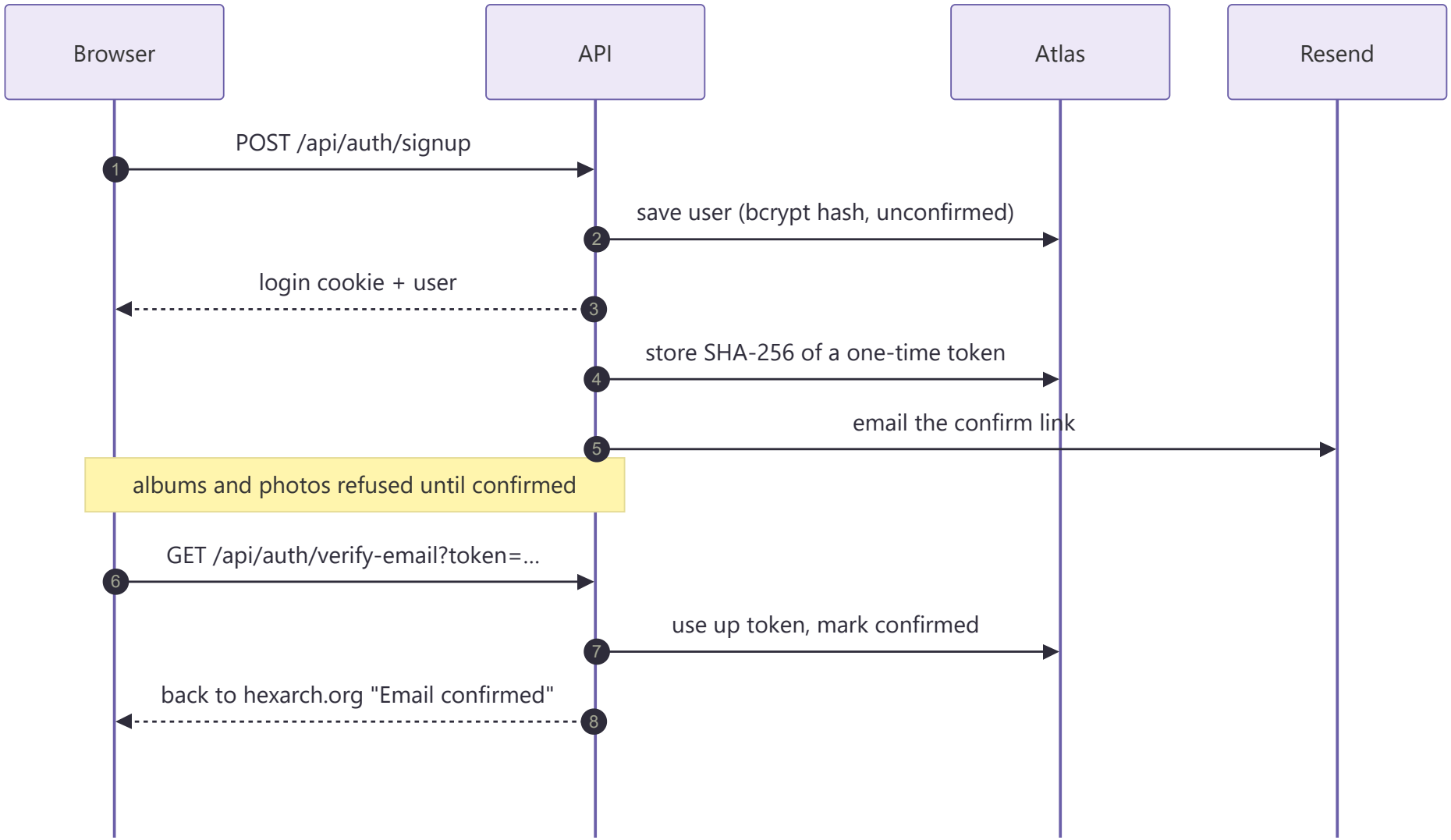
A person joins an album through a **Membership** (host or guest). Photo files live in R2; the database keeps only where each file is. **EmailToken** and **Invite** rows delete themselves when they expire.



4 · Flow: sign up and confirm email

POST /api/auth/signup → GET /api/auth/verify-email

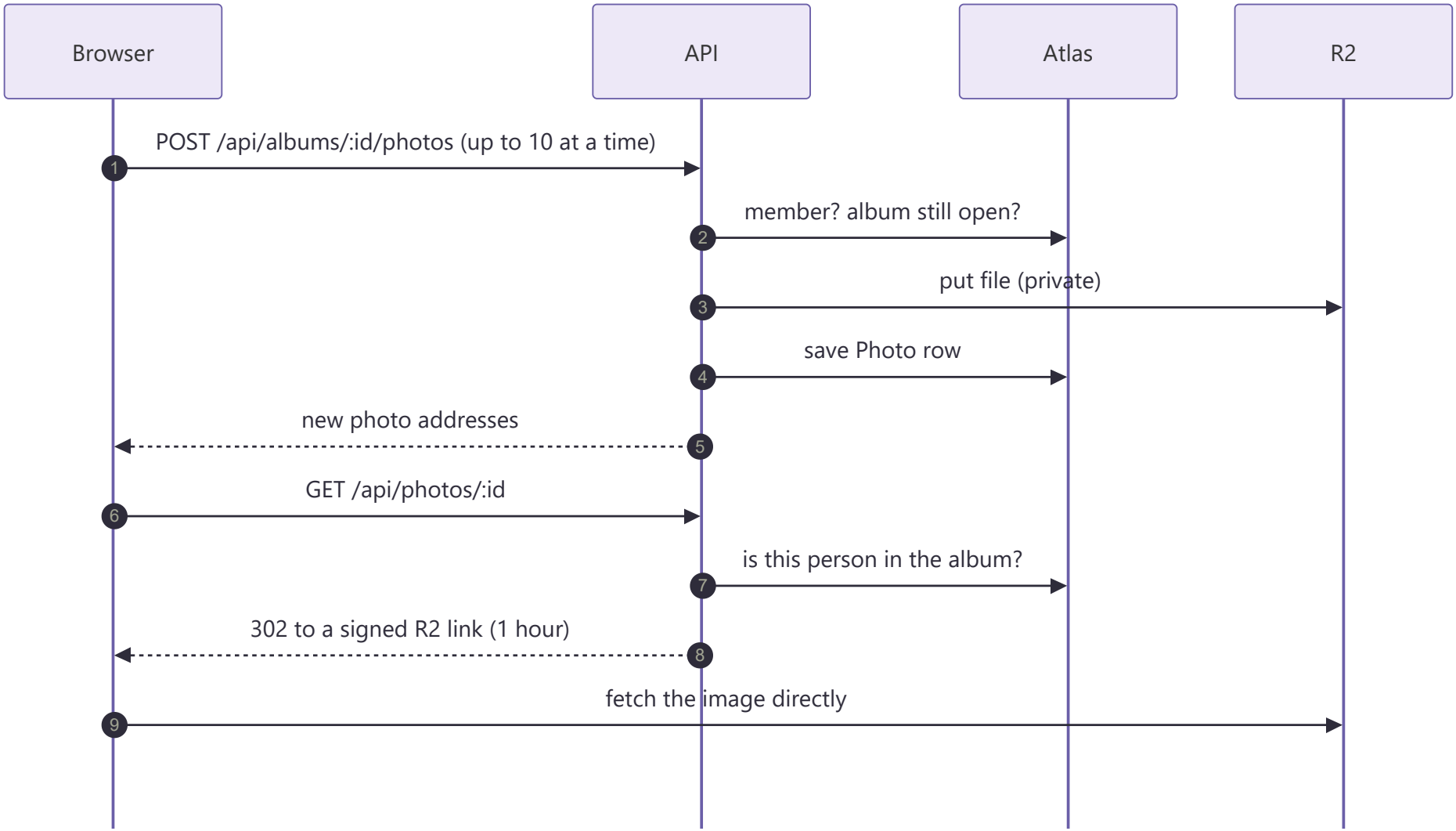
A new account is logged in straight away but can't open albums or photos until the link in the welcome email is opened. Only a SHA-256 of the link's token is stored, and it works once, for 24 hours.



5 · Flow: upload, then view a photo

POST /api/albums/:id/photos → GET /api/photos/:id

Uploads go up ten at a time and are refused once an album has closed. Viewing never streams the file through Render: the API checks membership, then hands the browser a private Cloudflare link that works for an hour.



Not built yet: image compression and thumbnails, removing GPS location from photos, server-side logout of stolen cookies, sign-up bot protection, database backups.